Travaux pratiques – Gestion des incidents

Objectifs

Faites appel à vos connaissances en procédures de gestion des incidents pour formuler des questions sur les scénarios d'incidents donnés.

Contexte/scénario

La gestion des incidents liés à la sécurité informatique est désormais au cœur de chaque entreprise. La gestion d'un incident peut s'avérer complexe et impliquer plusieurs groupes de collaborateurs. Toute entreprise doit disposer de standards pour la gestion des incidents, qu'elle mettra en œuvre sous la forme de politiques, de procédures et de listes de contrôle. Pour gérer un incident de manière efficace, l'analyste en sécurité doit être formé pour appliquer les mesures requises, tout en suivant les directives propres à l'entreprise. De nombreuses ressources sont disponibles pour aider les organisations à créer et à maintenir une stratégie de gestion des réponses aux incidents informatiques. La publication spéciale 800-61r2 du NIST est spécifiquement citée dans les sujets de l'examen Understanding Cisco Cybersecurity Operations Fundamentals (200-201 CBROPS).

Instructions

Scénario 1 : Contamination par un ver et un agent DDoS

Étudiez le scénario suivant et identifiez les questions qui doivent être posées à chaque étape du processus de gestion de l'incident. Tenez compte des caractéristiques de l'entreprise et du modèle CSIRC au moment de formuler vos questions.

Ce scénario concerne une petite entreprise familiale spécialisée dans l'investissement. Celle-ci emploie moins de 100 employés sur un site unique. Un mardi matin, on découvre qu'un nouveau ver se propage dans l'entreprise via des supports amovibles. Ce ver est capable d'insérer une copie de lui-même dans des partages Windows ouverts. Lorsque le ver infecte un hôte, il y installe un agent DDoS. Les signatures antivirus n'ont été générées que plusieurs heures après le début de la propagation du ver. Les systèmes de l'entreprise étaient déjà largement infectés.

La société d'investissement a embauché une petite équipe d'experts en sécurité qui utilisent souvent le modèle de gestion des incidents Diamond.

Préparation :

© 2018 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

Détection et analyse :

Confinement, éradication et rétablissement des systèmes :

Activités après l'incident :

Scénario 2 : Accès non autorisé à des données de paie

Étudiez le scénario suivant. Identifiez les questions qui doivent être posées à chaque étape du processus de gestion de l'incident. Tenez compte des caractéristiques de l'entreprise et du modèle CSIRC au moment de formuler vos questions.

Ce scénario concerne un hôpital de taille moyenne disposant de plusieurs services de soins et bureaux annexes. L'hôpital emploie plus de 5 000 employés sur de très nombreux sites. En raison de sa taille, l'hôpital a décidé de mettre en place des équipes de gestion des incidents (CSIRC) sur différents sites. Il dispose également d'une équipe de coordinateurs qui contrôlent les opérations des équipes de sécurité et les aident à communiquer entre elles.

Un mercredi soir, l'équipe chargée de la sécurité physique de l'hôpital reçoit un appel d'une administratrice du service Paie qui a vu un inconnu sortir de son bureau et quitter le bâtiment en courant. L'administratrice n'avait laissé son bureau ouvert et sans surveillance que pendant quelques minutes. Le programme de paie est toujours ouvert et le menu principal est tel qu'il était quand elle a quitté le bureau, mais elle a l'impression que la souris a été déplacée. L'équipe de gestion des incidents a été chargée de rassembler des preuves liées à l'incident et d'identifier les opérations effectuées.

Les équipes de sécurité utilisent le modèle de chaîne de frappe et savent se servir de la base de données VERIS. Pour renforcer la sécurité de l'hôpital, elles ont également fait appel à une équipe de gestion des incidents externe chargée de surveiller les systèmes 24 h/24, 7 j/7.

Préparation :

Détection et analyse :

Confinement, éradication et rétablissement des systèmes :

Activités après l'incident :

© 2018 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco